

Healthcare IAM Home Lab — 12-Week Daily Plan

Schedule: Mon–Thu, ~3 hrs/day, 144 total hours **Org size:** 30 simulated employees

Approach: Plan/design compressed to Week 1 only. Every day after that is hands-on build, test, or document-as-byproduct. No dedicated "documentation weeks."

Week 1 — Scenario, RBAC Skeleton, and First Build Steps

Day 1 (Mon) — Define the Organization and Scope Description: Name the fictional hospital, confirm 30 employees, list departments (Nursing, Pharmacy, Lab, Doctors, HR, Finance, IT, Security, Reception, Contractors), write a one-paragraph scope statement, and explicitly note what's out of scope (no custom app, no real hybrid sync). Deliverable: One-page scenario write-up + department list.

Day 2 (Tue) — RBAC Skeleton and Simulated Application List Description: For each department/role, define the "simulated application" it needs (EHR, Pharmacy System, Payroll, Lab System, HR Docs, IT Admin Tools). Sketch the OU structure and decide your security group naming convention (e.g., `SG-Nursing-RW`). Deliverable: RBAC matrix v1 (role → app → access level) + OU sketch.

Day 3 (Wed) — VirtualBox and Server VM Setup Description: Install VirtualBox, download Windows Server ISO, create the Server VM shell, configure RAM/CPU/disk. Deliverable: Server VM created and bootable from install media (screenshot).

Day 4 (Thu) — Install Windows Server OS Description: Install the OS, set hostname, configure static IP, verify network connectivity. Deliverable: Windows Server installed and reachable on your lab network (screenshot).

Week 2 — Domain Controller and Client

Day 1 (Mon) — Promote to Domain Controller Description: Install AD DS role, run the promotion wizard, create the domain, verify DNS. Deliverable: Functioning domain controller (screenshot of `dcdiag` or AD Users and Computers).

Day 2 (Tue) — Build the Client VM Description: Create the Windows Client VM shell, install the client OS. Deliverable: Client VM installed and network-connected.

Day 3 (Wed) — Join Client to Domain Description: Join the client to the domain, verify successful domain login. Deliverable: Screenshot of domain-joined client, logged in as a domain account.

Day 4 (Thu) — Build OU Structure Description: Create top-level department OUs and sub-OUs matching your Week 1 sketch. Deliverable: OU hierarchy visible in AD Users and Computers (screenshot).

Week 3 — Groups, Policy, and Users

Day 1 (Mon) — Create Security Groups Description: Create all security groups per your RBAC matrix (clinical, admin, IT/security), following your naming convention. Deliverable: Full group list created (screenshot).

Day 2 (Tue) — Password Policy via GPO Description: Configure complexity, minimum length, lockout threshold, and expiration via Group Policy. Verify it applied. Deliverable: GPO screenshot + confirmation the policy is enforced.

Day 3 (Wed) — Create First 15 Users Description: Create the first half of your 30 employees, placed in correct OUs and groups. Deliverable: 15 accounts created and verified.

Day 4 (Thu) — Create Remaining 15 Users Description: Finish the roster. Verify all 30 accounts' properties and group memberships. Deliverable: Full 30-user roster (screenshot of complete directory).

Week 4 — Simulated Applications and Entra ID Foundation

Day 1 (Mon) — Build On-Prem "Applications" via Shared Folders Description: Create shared folders for each simulated app (EHR-Records, Pharmacy-Systems, Payroll, etc.) and lock down NTFS permissions using your AD security groups. Deliverable: Working folder-permission RBAC — test login as two different roles and screenshot the access difference.

Day 2 (Tue) — Create Entra ID Tenant Description: Stand up the Microsoft Entra ID tenant. Briefly note (1–2 sentences) that real hybrid sync (Entra Connect) is out of scope for this lab. Deliverable: Active Entra tenant.

Day 3 (Wed) — Create Cloud Users and Groups Description: Create cloud users mirroring your on-prem AD (bulk CSV import if possible — good PowerShell practice), plus mirrored cloud groups. Deliverable: 30 cloud users + groups, screenshot of Entra ID user list.

Day 4 (Thu) — Build Simulated Enterprise Apps in Entra ID Description: Create custom Enterprise Applications (e.g., "MEDITECH EHR (Simulated)") and assign your cloud groups to them. Deliverable: App-to-group assignments visible in Entra ID (screenshot) — this is your cloud app-to-role mapping.

Week 5 — MFA and First Full JML Activity

Day 1 (Mon) — Enable MFA Description: Enable MFA in Entra ID, configure Microsoft Authenticator as the method. Deliverable: MFA policy active (screenshot).

Day 2 (Tue) — Enroll and Test MFA Description: Enroll at least one privileged account, test the MFA challenge on sign-in. Deliverable: Screenshot of a successful MFA challenge.

Day 3 (Wed) — Verify End-to-End Access Description: Test a full login flow for a regular user — domain login → app access via group assignment. Troubleshoot any gaps.

Deliverable: Confirmed working access chain for at least one role.

Day 4 (Thu) — Activity 1: Employee Onboarding Description: Run a full onboarding scenario (new nurse hire): create AD account, assign groups, provision cloud/app access, write it up as one ticket. Deliverable: Completed onboarding ticket + screenshots.

Week 6 — Transfer and Termination

Day 1 (Mon) — Activity 2: Employee Transfer Description: Simulate a department transfer (e.g., Emergency → ICU): remove old access, grant new access. Deliverable: Transfer executed in AD/Entra.

Day 2 (Tue) — Document Transfer + Quick Retro Description: Write the transfer ticket. Spend 15 minutes noting any gaps from Activities 1–2. Deliverable: Transfer ticket + short notes.

Day 3 (Wed) — Activity 3: Employee Termination Description: Simulate a contractor termination: disable account, strip group memberships, remove app access. Deliverable: Terminated account fully deprovisioned (screenshot before/after).

Day 4 (Thu) — Document Termination Description: Write the termination ticket with resolution notes. Deliverable: Completed termination ticket.

Week 7 — MFA Support and Access Review Setup

Day 1 (Mon) — Activity 4: MFA Support Description: Simulate a doctor losing their MFA device: verify identity per policy, reset MFA, re-enroll a new device. Deliverable: MFA reset completed + screenshot.

Day 2 (Tue) — Document MFA Ticket Description: Write the MFA support ticket. Deliverable: Completed MFA ticket.

Day 3 (Wed) — Plant Access Review Findings Description: Deliberately create 2–3 realistic issues (a stale/terminated account not fully removed, an over-permissioned group membership) to make your access review realistic. Deliverable: Issues planted and noted privately (not yet "found").

Day 4 (Thu) — Activity 5: Access Review Description: Pull current access assignments against your RBAC baseline, identify the planted issues plus any real ones, compile findings. Deliverable: Findings list.

Week 8 — Remediation and First Automation

Day 1 (Mon) — Write Access Review Report Description: Short report: findings + corrective actions. Keep it template-based, not an essay. Deliverable: Access review report v1.

Day 2 (Tue) — Remediate Findings Description: Fix everything you found — remove the stale account, correct the over-permissioned group. Deliverable: Environment matches RBAC baseline again (screenshot before/after).

Day 3 (Wed) — PowerShell: Query Scripts Description: Write a script using `(Get-ADUser)/(Get-ADGroupMember)` to pull a user/group report. Deliverable: Working PowerShell script + sample output.

Day 4 (Thu) — PowerShell: Automate Account Creation Description: Script the account-creation steps from Activity 1 (create user, add to groups) in PowerShell. Deliverable: Script that creates a new user end-to-end from one command.

Week 9 — More Automation, Expanded Roles

Day 1 (Mon) — PowerShell: Automate Deprovisioning Description: Script the termination steps (disable account, remove group memberships) from Activity 3. Deliverable: One-command deprovisioning script.

Day 2 (Tue) — Add Security, Reception, Contractor Roles Description: Build OUs/groups/simulated app access for the three roles you hadn't built yet. Deliverable: RBAC matrix updated and fully built out for all 10 roles.

Day 3 (Wed) — Contractor Auto-Expiration Description: Set `AccountExpirationDate` on contractor accounts to enforce your 90-day rule. Deliverable: Contractor accounts with expiration dates set (screenshot).

Day 4 (Thu) — Second Onboarding (Automated) Description: Run a second onboarding scenario using your new PowerShell script, for one of the new roles. Deliverable: Proof the process is repeatable and automatable.

Week 10 — Hardening and Second Review Cycle

Day 1 (Mon) — Conditional Access Policy Description: Configure a basic Conditional Access policy in Entra ID (e.g., require MFA for admin/privileged roles). Deliverable: Policy active (screenshot).

Day 2 (Tue) — Second Transfer/Termination Description: Run one more transfer and one more termination using a new role, to prove repeatability beyond the first pass. Deliverable: Executed and screenshotted.

Day 3 (Wed) — Second Access Review Description: Re-run the access review process. Compare against your Week 7–8 findings — show the environment is cleaner this time. Deliverable: Second findings list (should be shorter/cleaner).

Day 4 (Thu) — Update User Access Matrix Description: Finalize the User Access Matrix to reflect the current, fully-built state of the environment. Deliverable: Final User Access

Week 11 — Lightweight SOPs and Evidence Organization

Day 1 (Mon) — Draft All 4 SOPs in One Pass Description: Bullet-point SOPs (not essays) for: create account, disable account, reset MFA, run access review. Deliverable: 4 short SOP documents.

Day 2 (Tue) — Organize AD/Entra Screenshots Description: Sort all screenshots into labeled folders by category. Deliverable: Clean screenshot folder structure.

Day 3 (Wed) — Organize Ticket/Report Evidence Description: Sort ticket and report screenshots into a portfolio folder structure. Deliverable: Portfolio-ready evidence folder.

Day 4 (Thu) — Reconcile the Design Document Description: Update the design doc to match reality: fix the 30-employee count everywhere, complete the RBAC table (all 10 roles), fix SDLC week labels, remove leftover template header/footer. Deliverable: Design doc v2, fully consistent with the build.

Week 12 — Portfolio and Interview Prep

Day 1 (Mon) — Resume and LinkedIn Summaries Description: Write 3–4 resume bullets and a LinkedIn project summary highlighting the JML lifecycle, RBAC design, and PowerShell automation. Deliverable: Resume bullets + LinkedIn post draft.

Day 2 (Tue) — Interview Talking Points Description: Prepare a walkthrough: RBAC design decisions, each JML activity, the access review findings, and what you automated. Deliverable: Talking points doc.

Day 3 (Wed) — Final Proofread and Publish Description: Final pass on the design doc and portfolio; publish (GitHub/portfolio site). Deliverable: Published portfolio.

Day 4 (Thu) — Final Review and Closure Description: Check everything against your evaluation criteria from the design doc. Confirm nothing's missing. Deliverable: Project marked complete.